

Rapport n°1

Audit de sécurité : Approche ANTIC

Application auditée : GIDOCEP

Développeur : SOLTEC (Solutions Techniques)

Référence : ANTIC-AUDIT-2026-01

Document rédigé selon le modèle de rapport d'audit MUSA (Annexe I du mémoire)

En-tête du rapport

Titre	Audit de sécurité applicative de GIDOCEP : Approche ANTIC		
Référence	ANTIC-AUDIT-2026-01	Version	1.0
Application auditée	GIDOCEP	Niveau d'audit	☒ 2 ☐ 1 ☐ 3
Période d'audit	Mars - Avril 2026	Structure auditée	SOLTEC (Solutions Techniques)
Lead auditor	Expert en cybersécurité	Visa	
Date de transmission		Statut	☒ Provisoire ☐ Définitif
Classification	Confidentiel		

SECTION 1 Résumé exécutif

Métriques principales

Métrique	Valeur
Vulnérabilités techniques détectées	8
Vulnérabilités critiques	2
Vulnérabilités élevées	3
Vulnérabilités modérées	2
Vulnérabilités faibles	1

Forces identifiées

- 1. Séparation des environnements (développement / test / production)
- 2. Traçabilité des opérations comptables (journalisation des actions)
- 3. Expiration de session après inactivité

Vulnérabilités critiques

- 1. Injection SQL sur l'endpoint de recherche (/recherche?q=)
- 2. Hachage des mots de passe en MD5 sans sel

Recommandation principale

Corriger immédiatement les vulnérabilités critiques (injection SQL et hachage MD5) et mettre en place un processus de revue de code sécurisé.

SECTION 2 Contexte et périmètre

2.1 Organisation auditée

SOLTEC est une PME camerounaise spécialisée dans la conception, le développement et la maintenance de solutions informatiques pour les administrations publiques. L'entreprise compte moins de 20 employés.

2.2 Application auditée

GIDOCEP est une application de gestion comptable utilisée par les établissements publics camerounais pour l'exécution du budget. Elle gère les opérations de dépenses et de recettes selon le circuit : Ordonnateur- Contrôleur Financier - Agent Comptable.

2.3 Périmètre inclus

- Application GIDOCEP (production)
- Base de données HFSQL Classic
- Serveur IIS hébergeant l'application
- Interfaces utilisateur

2.4 Périmètre exclu

- Postes clients des utilisateurs
- Infrastructure réseau des établissements
- Applications tierces non développées par SOLTEC

2.5 Niveau d'audit

Niveau 2 (Standard) - 100 contrôles OWASP ASVS.

2.6 Contraintes et limitations

- Accès limité au code source (analyse statique partielle)
- Environnement de test non isolé
- Absence de documentation technique formalisée

SECTION 3 : Méthodologie

3.1 Référentiels utilisés

- OWASP ASVS v4.0.3 (100 contrôles)
- NIST SP 800-115 (méthodologie de tests)
- ISO 19011:2018 (conduite d'audit, partiellement)

3.2 Outils utilisés

Type de test	Outil
Scan réseau	Nmap
Scan vulnérabilités	Nuclei
Test dynamique (DAST)	OWASP ZAP
Tests manuels	Hydra, Burp Repeater

3.3 Équipe d'audit

- Auditeur principal : Expert en cybersécurité
- Auditeur technique : Spécialiste en tests d'intrusion

SECTION 4 Synthèse des résultats

4.1 Distribution des constats

Catégorie	Nombre
Conformes	11
Non conformes	8
Zones grises	2

4.2 Distribution des vulnérabilités par niveau de risque

Niveau	Nombre
Critique	2
Élevé	3
Modéré	2
Faible	1

4.3 Répartition par catégorie OWASP

Catégorie	Nb vulnérabilités
V2 - Authentification	3
V3 - Gestion de session	1
V5 - Validation des entrées	2
V6 - Cryptographie	1
V14 - Configuration	1

SECTION 5 Détail des vulnérabilités

Fiche n°1 (Critique)

Identifiant	ANTIC-001
Titre	Injection SQL sur l'endpoint de recherche
Catégorie OWASP	V5.3.1
Description	L'endpoint /recherche?q= est vulnérable à une injection SQL. L'application construit des requêtes SQL par concaténation de chaînes, permettant à un attaquant de modifier la requête et d'extraire des données.
Preuve	Capture d'écran ZAP-03 / Rapport SQLMap
Impact	Extraction de données de la base de données
Probabilité (P)	4 (Élevée)
Impact (I)	4 (Critique)
Score de risque	[object Object]
Recommandation	Remplacer les requêtes SQL par des requêtes paramétrées ou utiliser un ORM
Priorité	[object Object]
Échéance	48 heures
Responsable	Lead développeur SOLTEC

Fiche n°2 (Critique)

Identifiant	ANTIC-002
Titre	Hachage des mots de passe en MD5 sans sel
Catégorie OWASP	V2.1.5
Description	Les mots de passe des utilisateurs sont hachés avec l'algorithme MD5, considéré comme obsolète et vulnérable aux attaques par collision et par force brute. Aucun salage n'est appliqué.
Preuve	Extrait de code SAST-001
Impact	Compromission des comptes utilisateurs en cas de fuite de la base de données
Probabilité (P)	4 (Élevée)
Impact (I)	4 (Critique)
Score de risque	[object Object]
Recommandation	Migrer vers un algorithme de hachage robuste (bcrypt, Argon2) avec salage
Priorité	[object Object]
Échéance	48 heures
Responsable	Lead développeur SOLTEC

Fiche n°3 (Élevé)

Identifiant	ANTIC-003
Titre	Absence de mécanisme de blocage après échecs d'authentification
Catégorie OWASP	V2.1.4
Description	L'application n'implémente aucun mécanisme de blocage de compte après plusieurs échecs de connexion consécutifs.
Preuve	Test Hydra (10+ échecs sans blocage)
Impact	Risque d'attaque par force brute sur les comptes utilisateurs
Probabilité (P)	4 (Élevée)
Impact (I)	3 (Significatif)
Score de risque	[object Object]
Recommandation	Mettre en place un blocage de compte après 5 échecs consécutifs
Priorité	[object Object]
Échéance	2 semaines
Responsable	Lead développeur SOLTEC

Fiche n°4 (Faible)

Identifiant	ANTIC-004
Titre	Divulgateion de la version du serveur IIS
Catégorie OWASP	V14
Description	La version du serveur IIS est exposée dans les en-têtes HTTP des réponses, facilitant les attaques ciblées.
Preuve	Scan OWASP ZAP
Impact	Facilitation des attaques ciblées
Probabilité (P)	2 (Faible)
Impact (I)	1 (Négligeable)
Score de risque	[object Object]
Recommandation	Masquer la version du serveur dans les en-têtes HTTP
Priorité	[object Object]
Échéance	Planifié
Responsable	Administrateur système

#	Action	Priorité	Responsable	Échéance	Indicateur
1	Corriger l'injection SQL (requêtes paramétrées)	Critique	Lead dev	J+2	—
2	Migrer le hachage MD5 vers bcrypt/Argon2	Critique	Lead dev	J+2	—
3	Mettre en place un blocage après 5 échecs	Élevé	Lead dev	M+1	—
4	Configurer les en-têtes HTTP de sécurité	Élevé	Admin sys	M+1	—
5	Masquer la bannière serveur	Faible	Admin sys	M+3	—
6	Mettre en place une politique de mots de passe forts	Élevé	Lead dev	M+1	—

SECTION 7 Annexes

- Rapports OWASP ZAP
- Captures d'écran des vulnérabilités
- Résultats des tests Hydra

Limites de l'approche ANTIC

Ce que cette approche ne couvre pas :

- ✗ Ne détecte pas les failles de logique métier
- ✗ Ne vérifie pas la conformité fonctionnelle de l'application
- ✗ Ne prend pas en compte l'impact métier des vulnérabilités
- ✗ **Aucune** mesure de la reproductibilité des constats : nous avons utilisé le model de rapport que propose MUSA à fin d'avoir un rapport mesurable